

Risk Assessment Summary

Overview

Botium Toys is a small company with both a physical store and an expanding online business. As the company has grown internationally, its IT department has faced increasing pressure to support online services, manage customer data securely, and maintain compliance with industry regulations.

Audit Scope and Objectives

The audit focused on the company's overall security program, including:

- Employee devices and equipment
- Internal systems and networks
- Data storage and retention
- Ecommerce and inventory systems
- Legacy systems needing manual monitoring

The main objective was to identify security gaps, assess risks to business operations and sensitive data, and determine which controls and compliance measures should be improved.

Assets Reviewed

The IT department currently manages:

- Office equipment and business systems
- Employee workstations, laptops, smartphones, and accessories
- Internal network infrastructure
- Ecommerce, database, accounting, and inventory systems

- Internet connectivity
- Data storage and retention systems
- Legacy systems that need manual maintenance and monitoring
- Physical storefront and warehouse systems

Risk Assessment

The organisation was assessed as having a fairly high security risk due to missing security controls and incomplete compliance practices.

Key risks identified:

- Employees currently have wide access to internal and customer related data
- Customer payment information is not encrypted
- Least privilege and separation of duties controls have not been implemented
- No intrusion detection system (IDS) is currently installed
- Disaster recovery planning and data backup procedures are missing
- Password policies exist but do not meet modern complexity standards
- No centralised password management solution is in place
- Legacy systems are monitored inconsistently without a clear maintenance schedule

The audit identified an overall risk score of 8/10 due to the potential impact of data breaches, operational disruption, and regulatory non-compliance

Existing Security Controls

Some security controls are already implemented, including:

- Firewall protection
- Antivirus software
- Physical locks

- CCTV surveillance systems
- Data integrity and availability controls
- GDPR breach notification planning

Although these controls help reduce some risks, additional improvements are needed to strengthen the company's overall security posture.

Recommendations Summary

Recommended improvements include:

- Implement least privilege access controls
- Deploy encryption for customer payment data
- Install an intrusions detection system (IDS)
- Develop disaster recovery and backup procedures
- Strengthen password requirements
- Introduce centralised password management
- Improve monitoring and maintenance procedure for legacy systems